
Informe Profesional de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing.
Rodrigo Atilio Elgueta
Contratista: **Ramiro Gogol** — Username THM: gogolramiro
Ciclo Académico Vigente

Índice

1	Contexto de la Contratación	2
2	Modelo de Trabajo: Núcleo + Sala de Elección	2
2.1	Nivel 1 — Núcleo obligatorio	2
2.2	Nivel 2 — Sala de elección	2
3	PARTE II: INFORME DE PENTESTING	3
3.1	Datos generales	3
3.2	Pre-pentesting	3
3.3	Durante: Hallazgos por fase	4
3.4	Resumen ejecutivo de hallazgos	10
3.5	Post-pentesting: Recomendaciones	10
4	PARTE III: PROTOCOLO DE CONTINGENCIA	11
5	Anexos	12
6	Fuentes y bibliografía	12

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Ramiro Gogol — Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (branch gogol-ramiro).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio

Núcleo Obligatorio

1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>

Metodología y fases del pentesting profesional.

2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingjt>

Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección

Sala elegida: **Vulniversity** (<https://tryhackme.com/room/vulniversity>). Enfoque web + explotación de carga de archivos y escalada de privilegios por binario SUID. Justificación en la Sección 3.2.

3. PARTE II: INFORME DE PENTESTING

3.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Ramiro Gogol
DNI	46.060.802
Username TryHackMe	gogolramiro
Email institucional	gogolramiro@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	gogol-ramiro
Fecha de inicio	01/10/2026
Fecha de cierre	07/10/2026

3.2. Pre-pentesting

Alcance del trabajo

Dentro del alcance: exclusivamente las máquinas virtuales asignadas en la plataforma TryHackMe, accedidas a través de la VPN oficial de THM:

- **Basic Pentesting** (núcleo obligatorio) — máquina Linux con servicios web, SSH y Samba.
- **Vulniversity** (sala de elección) — máquina Linux con servicios FTP, SSH, Samba, proxy Squid y servidor web Apache.

Fuera del alcance: toda infraestructura real de INSECUR S.A., cualquier sistema de terceros, la propia plataforma TryHackMe y la infraestructura de red de la facultad. No se realizaron ataques de denegación de servicio ni pruebas destructivas.

Reglas de Enfrentamiento (ROE)

- Las pruebas se ejecutaron únicamente contra las IP asignadas dinámicamente por TryHackMe, y solo mientras las máquinas estuvieron desplegadas por el estudiante.
- Se trabajó sobre entornos de laboratorio aislados; no se accedió a datos reales ni personales.
- La fuerza bruta (Hydra) se limitó a 4–16 hilos para no degradar el servicio, y se detuvo al hallar la primera credencial válida (`-f`).
- No se instaló persistencia ni puertas traseras; el único artefacto cargado (web shell) se utilizó para obtener acceso y no se dejó operativo tras la prueba.
- Las credenciales y claves privadas obtenidas se trataron como material sensible: no se incluyen en texto plano en el repositorio; solo se documenta la evidencia de su compromiso.

Autorización

Declaro contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las pruebas de intrusión sobre los entornos de laboratorio de TryHackMe indicados en el alcance. Todas las actividades las desarrollé con fines exclusivamente académicos, dentro de dichos entornos controlados.

Metodología utilizada

Se adoptó una metodología basada en **PTES (Penetration Testing Execution Standard)**, complementada con la **NIST SP 800-115** y, para la parte web, la **OWASP Web Security Testing Guide (WSTG)**.

Justificación: PTES ofrece un marco de fases claro y ampliamente adoptado (pre-engagement, reconocimiento, escaneo, explotación, post-explotación y reporte) que se alinea con el flujo pedagógico de la actividad. NIST SP 800-115 aporta rigor técnico y trazabilidad de la evidencia, mientras que OWASP WSTG resulta pertinente para las vulnerabilidades de la capa web encontradas (carga de archivos sin validación).

3.3. Durante: Hallazgos por fase

A continuación se documenta cada hallazgo relevante. Se emplea el prefijo **BP** para Basic Pentesting y **VV** para Vulnversity.

Campo	Valor
ID del hallazgo	BP-01
Máquina	Basic Pentesting
Fase	☒ Escaneo ☒ Explotación
Descripción	El usuario del sistema jan posee una contraseña débil (armando) que fue obtenida mediante fuerza bruta sobre el servicio SSH con el diccionario rockyou.
Componente afectado	Servicio SSH (puerto 22) / cuenta de usuario jan .
Categoría (OWASP/CWE)	CWE-521 (Weak Password Requirements), CWE-307 (Improper Restriction of Excessive Authentication Attempts).
CVE (si aplica)	No aplica (mala configuración / política de credenciales).
CVSS estimado	☒ Alto
Evidencia	evidencias/basic-pentesting/explotacion/explotacion.hydra.png (Hydra devuelve login: jan / password: armando).
Herramienta utilizada	nmap, enum4linux, hydra.

Impacto en la Tríada CIA ☒ Confidencialidad ☒ Integridad

Salvaguarda propuesta Imponer política de contraseñas robustas, deshabilitar autenticación por contraseña en SSH (usar claves), y aplicar `fail2ban` para bloquear intentos de fuerza bruta.

Riesgo residual ☒ Bajo

Campo	Valor
ID del hallazgo	BP-02
Máquina	Basic Pentesting
Fase	☒ Post-explotación
Descripción	La clave privada SSH del usuario <code>kay</code> (<code>/home/kay/.ssh/id_rsa</code>) era legible por otros usuarios y su passphrase de cifrado era débil (<code>beeswax</code>), recuperable con John the Ripper. Esto permitió el movimiento lateral de <code>jan</code> a <code>kay</code> .
Componente afectado	Permisos de la clave privada SSH de <code>kay</code> .
Categoría (OWASP/CWE)	CWE-522 (Insufficiently Protected Credentials), CWE-732 (Incorrect Permission Assignment).
CVE (si aplica)	No aplica.
CVSS estimado	☒ Alto
Evidencia	<code>evidencias/basic-pentesting/post/post_john_passphrase.png</code> (John recupera la passphrase <code>beeswax</code>).
Herramienta utilizada	<code>ssh2john</code> , John the Ripper, <code>ssh</code> .
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad
Salvaguarda propuesta	Restringir permisos de claves privadas a 600 y al propietario; usar passphrases robustas; no almacenar claves privadas accesibles por otros usuarios.
Riesgo residual	☒ Bajo

Campo	Valor
ID del hallazgo	BP-03
Máquina	Basic Pentesting
Fase	☒ Post-explotación
Descripción	En el directorio personal de kay existía el archivo pass.bak con una contraseña en texto plano, que permitió escalar privilegios a root mediante sudo .
Componente afectado	Almacenamiento de credenciales en texto plano (/home/kay/pass.bak).
Categoría (OWASP/CWE)	CWE-312 (Cleartext Storage of Sensitive Information), CWE-256 (Unprotected Storage of Credentials).
CVE (si aplica)	No aplica.
CVSS estimado	☒ Alto
Evidencia	evidencias/basic-pentesting/post/post_root_flag.png (acceso root vía sudo con la credencial de pass.bak).
Herramienta utilizada	Shell interactiva, cat , sudo .
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Nunca almacenar credenciales en texto plano; usar un gestor de secretos; aplicar el principio de mínimo privilegio en sudoers .
Riesgo residual	☒ Bajo

Campo	Valor
ID del hallazgo	BP-04
Máquina	Basic Pentesting
Fase	☒ Enumeración

Descripción	El servicio Samba (puertos 139/445) permitía enumeración anónima (sesión nula), exponiendo los nombres de usuario del sistema (jan , kay), información útil para los ataques posteriores.
Componente afectado	Servicio Samba/SMB.
Categoría (OWASP/CWE)	CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor).
CVE (si aplica)	No aplica (configuración).
CVSS estimado	☒ Medio
Evidencia	<code>evidencias/basic-pentesting/escaneo/escaneo_enum4linux.png</code> .
Herramienta utilizada	<code>enum4linux</code> .
Impacto en la Tríada CIA	☒ Confidencialidad
Salvaguarda propuesta	Deshabilitar sesiones nulas en Samba (restrict anonymous), limitar el acceso a los recursos compartidos y exponer SMB solo a redes internas confiables.
Riesgo residual	☒ Bajo

Campo	Valor
ID del hallazgo	VV-01
Máquina	Vulnversity
Fase	☒ Escaneo ☒ Explotación
Descripción	El formulario de carga de archivos del servidor web (puerto 3333, directorio /internal/) validaba la extensión de forma deficiente. Mediante fuzzing con Burp Suite Intruder se determinó que la extensión .phtml evadía el filtro, permitiendo subir y ejecutar un reverse shell PHP (ejecución remota de código) y obtener una shell como www-data .
Componente afectado	Funcionalidad de subida de archivos (Apache en puerto 3333).

Categoría (OWASP/CWE)	OWASP A03:2021 (Injection) / A05 (Security Misconfiguration); CWE-434 (Unrestricted Upload of File with Dangerous Type).		
CVE (si aplica)	No aplica (vulnerabilidad de lógica/validación).		
CVSS estimado	☒ Crítico		
Evidencia	<code>evidencias/vulnversity/explotacion/explotacion_burp_intruder.png</code> , <code>explotacion_shell_wwwdata.png</code> .		
Herramienta utilizada	gobuster, Burp Suite (Intruder), php-reverse-shell, netcat.		
Impacto en la Tríada CIA	☒ Confidencialidad	☒ Integridad	☒ Disponibilidad
Salvaguarda propuesta	Validar el tipo real del archivo (contenido/MIME, no solo la extensión) con lista blanca estricta; almacenar los archivos subidos fuera del <i>webroot</i> y sin permisos de ejecución; renombrar los archivos del lado del servidor.		
Riesgo residual	☒ Bajo		

Campo	Valor
ID del hallazgo	VV-02
Máquina	Vulnversity
Fase	☒ Post-explotación
Descripción	El binario <code>/bin/systemctl</code> tenía el bit SUID activado indebidamente. Desde el usuario <code>www-data</code> se abusó de esta mala configuración creando un servicio malicioso ejecutado como <code>root</code> , logrando la escalada total de privilegios y la lectura de la flag de <code>root</code> .
Componente afectado	Permisos del binario <code>/bin/systemctl</code> (bit SUID).
Categoría (OWASP/CWE)	CWE-250 (Execution with Unnecessary Privileges), CWE-732 (Incorrect Permission Assignment).
CVE (si aplica)	No aplica (mala configuración de permisos).
CVSS estimado	☒ Crítico

Evidencia	evidencias/vulniversity/post/post_suid.systemctl.png, post_flag_root.png.		
Herramienta utilizada	find (búsqueda SUID), systemctl.		
Impacto en la Tríada CIA	☒ Confidencialidad	☒ Integridad	☒ Disponibilidad
Salvaguarda propuesta	Quitar el bit SUID (<code>chmod u-s /bin/systemctl</code>); auditar periódicamente los binarios SUID; aplicar el principio de mínimo privilegio.		
Riesgo residual	☒ Bajo		

Campo	Valor
ID del hallazgo	VV-03
Máquina	Vulniversity
Fase	☒ Escaneo
Descripción	Superficie de ataque amplia: la máquina expone múltiples servicios (FTP, SSH, Samba, proxy Squid 4.10 y Apache en un puerto no estándar 3333), varios revelando banners con número de versión que facilitan la identificación de vulnerabilidades.
Componente afectado	Configuración de servicios y exposición de versiones.
Categoría (OWASP/CWE)	OWASP A05:2021 (Security Misconfiguration); CWE-200.
CVE (si aplica)	No aplica directamente.
CVSS estimado	☒ Bajo
Evidencia	evidencias/vulniversity/escaneo/escaneo_nmap.png.
Herramienta utilizada	nmap.
Impacto en la Tríada CIA	☒ Confidencialidad

Salvaguarda propuesta	prop-	Reducir la superficie de ataque (cerrar/deshabilitar servicios innecesarios), ocultar los banners de versión y mantener los servicios actualizados.
Riesgo residual	☒ Bajo	

3.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	VV-01, VV-02
Alto	3	BP-01, BP-02, BP-03
Medio	1	BP-04
Bajo	1	VV-03
Total	7	

Conclusión ejecutiva: ambas máquinas fueron comprometidas hasta obtener privilegios de **root**. Las causas raíz predominantes son **credenciales débiles o mal protegidas** y **malas configuraciones** (validación de carga de archivos y permisos SUID). Ninguna de las vulnerabilidades requirió exploits de día cero: todas derivan de prácticas de endurecimiento (hardening) ausentes, lo que indica que un plan de remediación de bajo costo reduciría drásticamente el riesgo.

3.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Priorizadas por criticidad:

1. **(Crítico)** Corregir la validación de carga de archivos: lista blanca por contenido/MIME, almacenamiento fuera del webroot y sin ejecución, y renombrado del lado del servidor (VV-01).
2. **(Crítico)** Quitar el bit SUID de `/bin/systemctl` y auditar todos los binarios SUID del sistema (VV-02).
3. **(Alto)** Imponer políticas de contraseñas robustas y desactivar la autenticación por contraseña en SSH a favor de claves; implementar `fail2ban` (BP-01).
4. **(Alto)** Restringir los permisos de las claves privadas SSH a 600 y proteger sus passphrases (BP-02).
5. **(Alto)** Eliminar toda credencial almacenada en texto plano y adoptar un gestor de secretos (BP-03).
6. **(Medio/Bajo)** Deshabilitar sesiones nulas en Samba, reducir servicios expuestos y ocultar banners de versión (BP-04, VV-03).

Recomendaciones administrativas (políticas y procesos)

- Establecer una **política de contraseñas** corporativa (longitud, complejidad, rotación) y de gestión de credenciales/secretos.
- Implementar un **proceso de hardening** y una línea base de configuración segura para todos los servidores, con revisiones periódicas.
- Realizar **auditorías de seguridad y pentests** de forma regular.
- Capacitar al personal técnico en desarrollo seguro (validación de entradas, manejo de archivos) y en el principio de mínimo privilegio.
- Mantener un **inventario de activos y servicios** expuestos y un ciclo de gestión de parches.

4. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Durante la fase de explotación se cargó y ejecutó un reverse shell en el servidor web (VV-01). En un entorno de producción, la subida y ejecución de archivos arbitrarios, o la posterior manipulación de servicios con `systemctl` (VV-02), podría provocar la **caída o indisponibilidad del servicio web** de INSECUR S.A., corrupción de datos o la ejecución de un servicio malicioso que afecte la estabilidad del host.

Impacto sobre la continuidad del negocio

Se vería afectado principalmente el **servicio web público** de INSECUR S.A. (portal/aplicación), con posible indisponibilidad total durante el incidente. Un compromiso de `root` implica además riesgo de fuga de datos confidenciales y pérdida de integridad de la información. El tiempo de afectación dependería de la detección y de la existencia de respaldos; se estima entre 1 y 4 horas hasta la restauración si se cuenta con backups y procedimientos definidos.

Plan de respuesta

1. **Activación:** detección mediante monitoreo (IDS/IPS, alertas de integridad de archivos en el webroot, picos de CPU/red, logs de subida anómala).
2. **Contención (primeros 15 minutos):** aislar el servidor afectado de la red, suspender el servicio de carga de archivos, bloquear la IP origen y preservar evidencia (logs, memoria).
3. **Recuperación:** restaurar el servicio desde un backup limpio o un servidor espejo, aplicar los parches/configuraciones correctivas (validación de uploads, remoción de SUID), rotar credenciales y claves comprometidas.
4. **Comunicación:** notificar a la dirección de TI, al responsable de seguridad y, según corresponda, a clientes y a las autoridades regulatorias.
5. **Post-mortem:** documentar el incidente, la causa raíz y las lecciones aprendidas; actualizar la línea base de hardening y los controles de detección.

RTO y RPO estimados**RTO** (Recovery Time Objective): 4 horas.**RPO** (Recovery Point Objective): 24 horas (último respaldo diario).**5. Anexos****Anexo A — Bitácora de comandos**

Archivos en el branch: `bitacora/clase-basicpentest_20261006.txt` y `bitacora/clase-vulniversity_20261007.txt`. Los comandos fueron depurados de credenciales/secretos antes de su publicación.

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por máquina y fase: `evidencias/basic-pentesting/{reconocimiento,escaneo,explotacion,post}` y `evidencias/vulniversity/{reconocimiento,escaneo,explotacion,post}`.

Anexo C — Hashes de las flags obtenidas

```

1 # Formato: flag_id  sha256_hash
2
3 # Basic Pentesting
4 BP-root (flag.txt)  852
   afba51134631548962400b2970b958e1a5b3cf52c48ee1433d9930fcb2a21
5
6 # Vulniversity
7 VV-user
   d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
8 VV-root
   cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

```

Nota: BP-root es el SHA-256 del archivo `/root/flag.txt`; VV-user y VV-root son el SHA-256 del valor de cada flag.

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Ramiro Gogol

07/10/2026

Firma — Ramiro Gogol (DNI 46.060.802)

Fecha

6. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- TryHackMe. *Vulniversity*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)

- PTES. *Penetration Testing Execution Standard*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.